Risikostyring

Agenda

Hva er styring av sikkerhet?

Hva er risikostyring?

Hva er risikovurdering?

Begreper

Litt om oblig 3

Oppgaver?

Forord

Uendelige med begreper og standarder etc

Fokuset er ikke på forståelse, som det er pugging...

- Ref. Første gruppetime

Kort repitisjon av det JEG tror er det viktigste

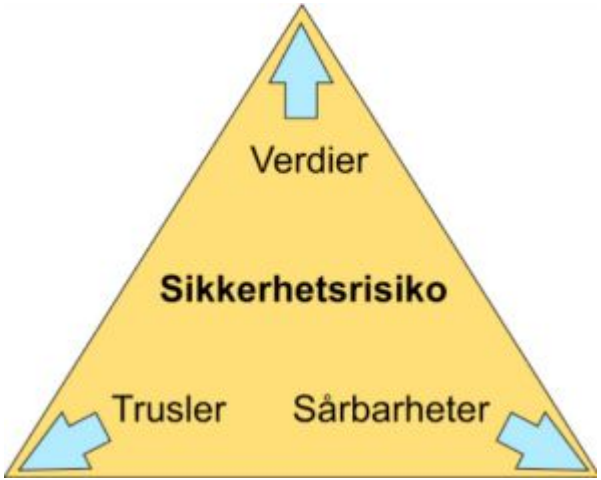
Kort repetisjon

Risiko: Kombinasjon av trussel, sårbarheter og verdier

Krav til informasjonsikkerhet kan komme fra f.eks **risikovurderinger**

Tiltak/standarder for å oppfylle krav til sikkerhet:

- ISO/IEC 27002
- NSMs grunnprinsipper
- NIST Cybersecurity Framework
- CIS Controls
- NIST SP 800-53



Styring av sikkerhet

"*Styring av informasjonssikkerhet* er å definere strategiske målsettinger for informasjonssikkerhet, sørge for at disse blir oppnådd, styre sikkerhetsrisiko med effektiv bruk av organisatoriske ressurser, påse at styringssystemet for informasjonssikkerhet fungerer hensiktsmessig og at resultater følger forventninger og målsettinger."

Styring av sikkerhet

TL;DR:

- Sett strategiske sikkerhetsmål, sørg for at de nås, håndter risiko effektivt, og kontroller at styringssystemet fungerer som det skal.
- Deles videre inn i ulike målsettinger

Strategiske sikkerhetsmål:

For eksempel:

- "Vi skal sikre at kun autoriserte får tilgang til kundedata" ➜ Konfidensialitet

- "Vi skal sikre at systemer er tilgjengelige 99,9% av tiden" ➜ Tilgjengelighet

Intern sikkerhetsledelse: ISMS/LSIS

“Planen” for hvordan en bedrift skal drive med sikkerhet kalles *Information Security Management System* (ISMS) eller på godt norsk: “*Ledelsessystem for informasjonssikkerhet”* (LSIS).

Ledelse av informasjonssikkerhet bør være basert på ISMS, som igjen er forankret i lover, standarder, rammeverk og policyer

Hvor god ISMS-en sier noe om modenheten til bedriften.

Tl;DR: Bedre ISMS = høyere modenhet

Standarder og rammeverk

ISO/IEC 27000-serien av sikkerhetsstandarder:

- ISO/IEC 27000 Beskrivelse av ISMS og begreper for informasjonssikkerhet
- ISO 27001: ISMS. Ledelsessystem for informasjonssikkerhet - Krav
- ISO 27002: Tiltak for informasjonssikkerhet
- etc.

USA

- NIST SP800-Series (Special Publications on Information Security)
- NIST Cyber Security Framework
- SANS Institute og CIS

Norge

- NSM, Digdir, Datatilsynet - Veiledere i sikkerhetsstyring

Mål for sikkerhetstyring

Strategisk tilpasning av sikkerhetsprogrammet

- Skal støtte organisasjons helhetlige strategi

Risikohåndtering

- Avdekke relevante trusler og risiko, innføre tiltak

Verdiskaping

- Balanse mellom ressursbruk og reduksjon av risiko

Ressursbruk

- Mulig gjenbruk og effektivisering
- Bygge, bruke og ivareta kompetanse

Målbarhet

Integrering av sikkerhetsområder

- Fysisk, finansiell, IT, etc



Poenget?

TL;DR av mål:

- Sikre verdiens informasjonsverdier på best mulig måte billigst mulig, og det skal være målbart slik at en kan se effekten over tid

Dette gjøres fordi **enhver bedrift** har behov for sikkerhet, og da trenger man en god plan for hvordan dette skal gjøres og følges opp.

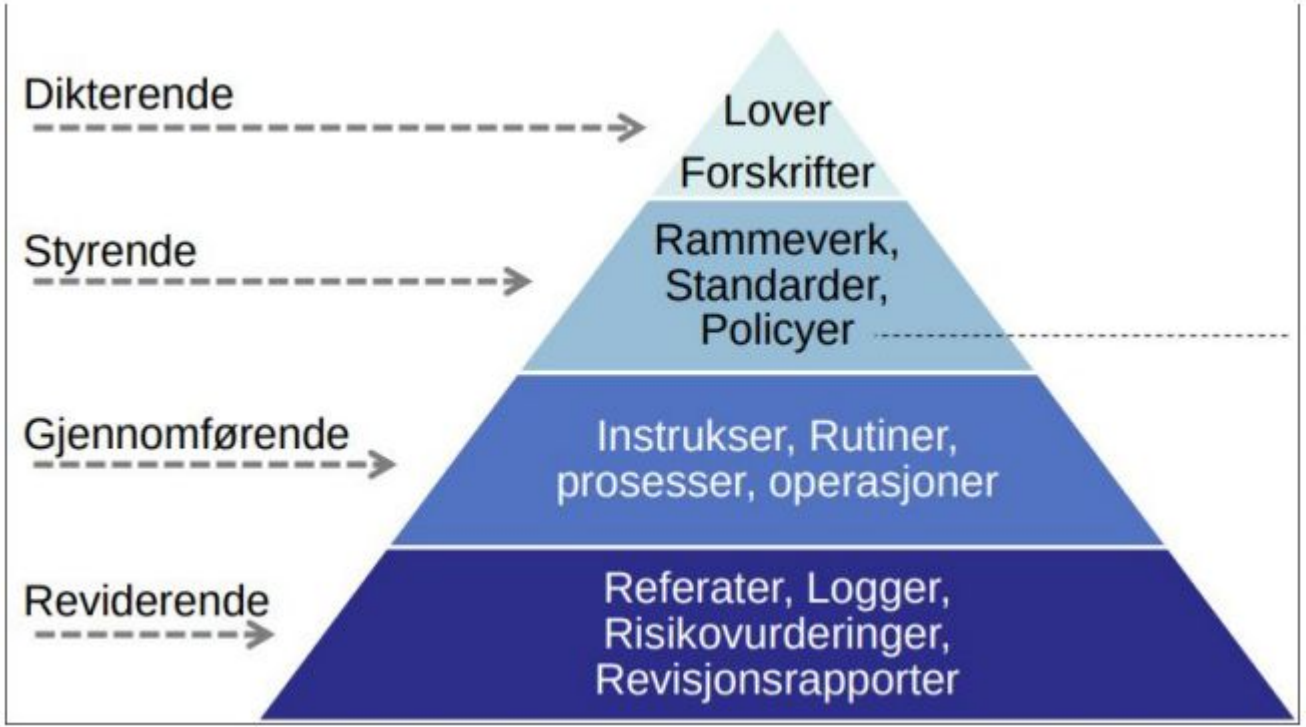


Kjennetegn for god sikkerhetsstyring

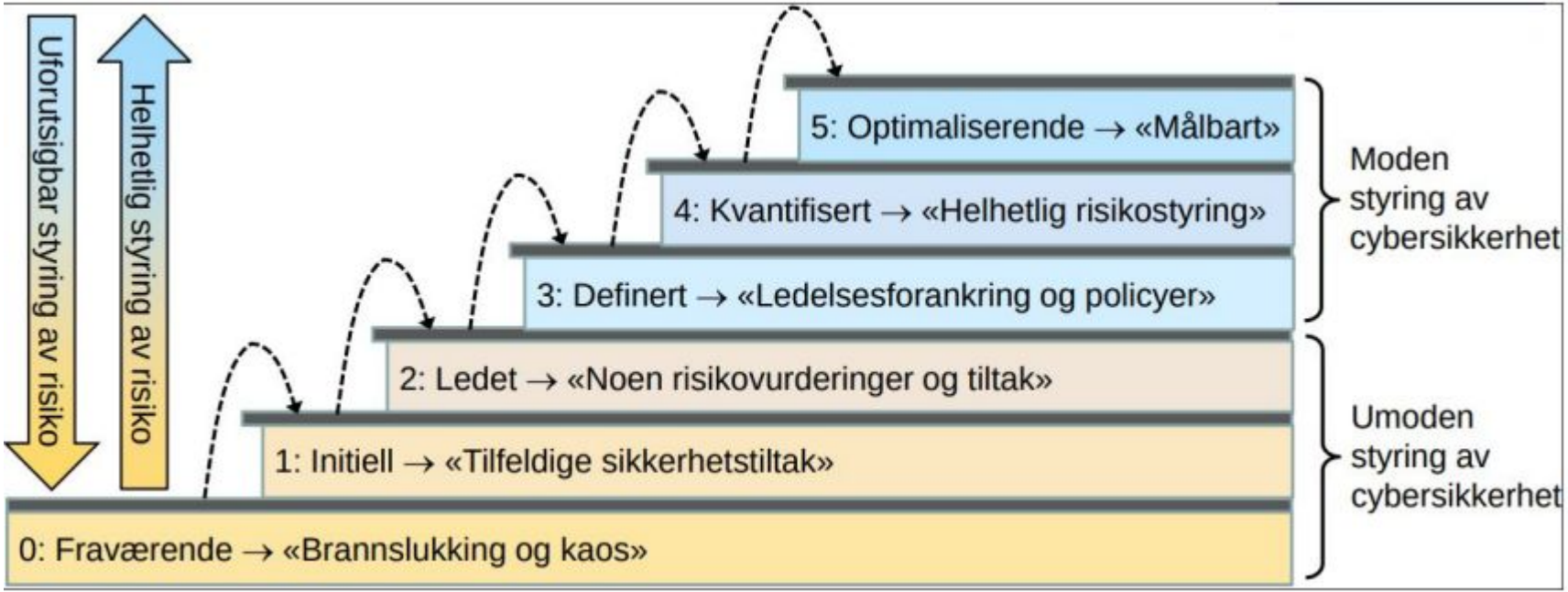
- Gjelder for hele virksomheten (ikke enkelte deler)
- Informasjonssikkerhet er et fundamentalt krav
- Ledelsen er godt informert
- Ledelsen viser ansvar og regnskapelighet
- Risikobasert prioritering
- Roller og ansvarsområder er veldefinerte



Dokumenthierarki



Modenhet i styring og ledelse



Risikostyring

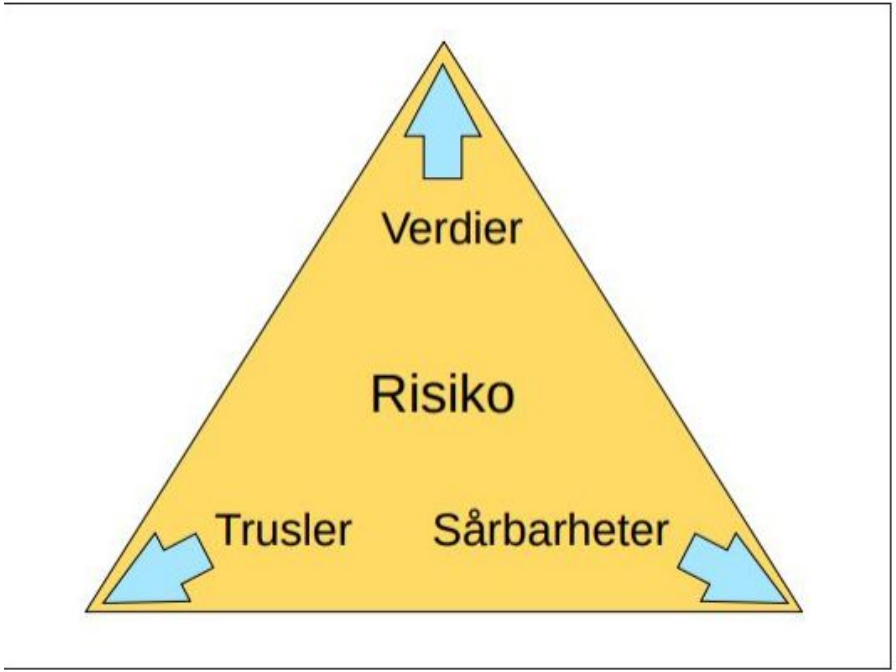
Repetisjon: “Kombinasjon av trussel, sårbarheter og verdier”

ISO 31000 og ISO 27000:

- “Risiko er effekten av uvisshet rundt oppnåelse av målsettinger”

ISO/IEC 27005:

- “Informasjonssikkerhetsrisiko er potensialet for at en gitt trussel vil utnytte sårbarheter rundt verdier og dermed skade organisasjonen.”



Hva er risikostyring

ISO 31000:

- *«Risikostyring består av koordinerte aktiviteter for å styre og lede en organisasjon med hensyn til risiko.»*

Ulike mål for risikostyringsaktiviteter:

- å få oversikt over verdier
- å få oversikt over trusler
- å få oversikt over sårbarheter
- å få oversikt over eksisterende risikoer
- å vurdere risikoene
- å foreslå nye sikkerhetstiltak
- å vurdere restrisiko etter nye foreslåtte sikkerhetstiltak
- å gi grunnlag for å kjøpe cyberforsikring
- å gi grunnlag for budsjett for håndtering av risiko

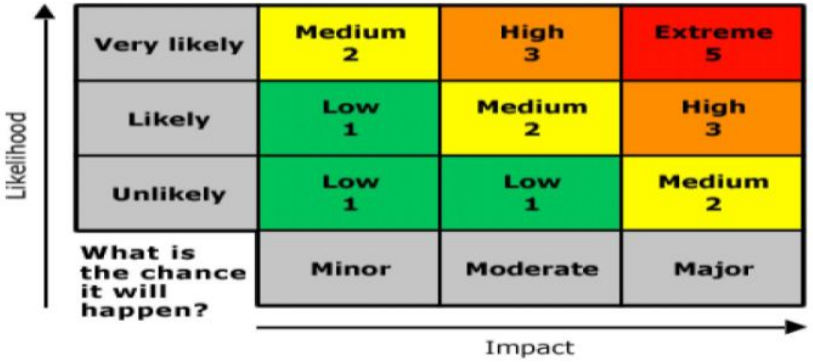
Risikovurdering

En risikovurdering er:

- “En prosess for å identifisere verdier, trusler, sårbarheter og konsekvenser, for deretter å vurdere sannsynlighet og risikoens alvorlighetsgrad.”

TL;DR:

- Hva kan gå galt?
- hvor sannsynlig?
- Hva er konsekvensene?
- Hva kan vi gjøre for å redusere risiko
- *Likelihood vs. impact*



Risikovurdering

I en risikovurdering, vurderer vi gjerne:

- Risikoidentifisering: Hva **kan være en** risiko?
- Risikoanalyse: **Hvor mye** av en risiko er det?
- Risikoevaluering: **Rangeringen** av risiko

Risikomodell: Trusselaktør -> risikonivå



Motivasjon x kapasitet	Trinn aktøren kan utføre	Svakheter angrepet utnytter	Brudd på KIT + P	Data. systemer, tjenester

Sannsynlighet x Konsekvens = Risikonivå

- Motivasjon, kapasitet, sårbarhet og konsekvens bestemmer risikonivået.

Risikonivå og risiko er ikke det samme

Risiko

- *hva som kan skje*

- En kombinasjon av trussel, sårbarhet og verdi som kan gi skade
- Finnes ved **risikoidentifisering**.
- **Trussel + sårbarhet + verdi**

Risikonivå

- *hvor stort nivået er*

- Størrelsen på risikoen. Det kalles også risikoeksponering.
- Beregnes ved **risikoanalyse**.
- Beregnes ved **risikoanalyse**.

Oblig 3 - Risikostyring

Se gjennom tidligere materiale (workshop, forelesningslides, ukesoppgaver, etc)

Ikke overtenk resultatene. Det finnes ingen “riktige svar” i virkelighet

- Fokuser på å begrunne valgene man tar
- Ikke overtenk tallene

Kan ta tid, start tidlig!

- Ikke nødvendigvis *vanskelig*, bare tar lang tid.

Oblig 3 – hvilke slides er verdt å se på

Forstå hva en risiko er (gjelder hele oppgaven):

- Risikostyring (7b) slide 5–9 – risikomodellen + forskjell på risiko og risikonivå
- Risikostyring (7b) slide 21 – hvordan finne trussel / sårbarhet / hendelse

Del I – terskel for akseptabel risiko:

- Risikostyring (7b) slide 32 – risikonivåer 0–10 (hva som er lav/moderat/høy)

Del II – kalibrering av S og V:

- Risikostyring (7b) slide 35 – S (snarest sannsynlighet)
- Risikostyring (7b) slide 36 – V (verst konsekvens)

Del III – fylle ut radene i regnearket:

- Risikostyring (7b) slide 30 – sannsynlighetsskala 1–5
- Risikostyring (7b) slide 31 – konsekvensskala 1–5
- Risikostyring (7b) slide 40 – hva hver kolonne i regnearket betyr

Del IV – visualisering før/etter tiltak:

- Risikostyring (7b) slide 41 – akkurat figuren dere skal lage

Ansvarsfordeling Expera vs UniKunn (nyttig for Del III):

- ISM (7a) slide 33 – Cyberforsvarsmatrisen for ansvarsfordeling

Eksamen 2024

35 **ISMS**

Hva er riktig om ISMS (Information Security Management System)?
Poeng: 0,5 for riktig, -0,5 for feil, 0 for ubesvart.
Velg ett eller flere alternativer

- [ ] Det er en applikasjon som styrer sikkerheten i virksomheter.
- [ ] Det er et sett med policyer og prosedyrer for informasjonssikkerhet.
- [ ] NSMs grunnprinsipper for IKT-sikkerhet er et ISMS.
- [ ] Det betyr det samme som ledelsessystem for informasjonssikkerhet.

Maks poeng: 1

35 ISMS

Hva er riktig om ISMS (Information Security Management System)?
Poeng: 0,5 for riktig, -0,5 for feil, 0 for ubesvart.
Velg ett eller flere alternativer

- [ ] Det er et sett med policyer og prosedyrer for informasjonssikkerhet. ✔
- [ ] NSMs grunnprinsipper for IKT-sikkerhet er et ISMS.
- [ ] Det betyr det samme som ledelsessystem for informasjonssikkerhet. ✔
- [ ] Det er en applikasjon som styrer sikkerheten i virksomheter.

Maks poeng: 1

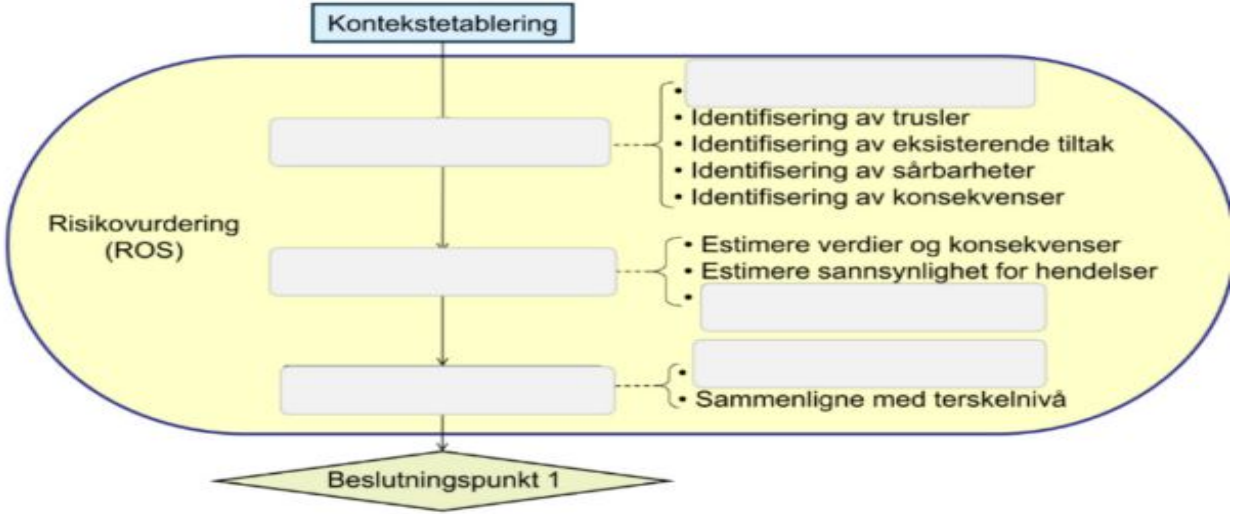
Eksamen 2024

34 Prosess for risikovurdering

Figuren nedenfor viser prosess for risikovurdering der noen av trinnene mangler beskrivelse.
Sett inn elementene i riktig felt for å beskrive trinnene.
Poeng: 0,5p for hver riktig; -0.5p for hver feil; 0p for ubesvart; 3p for alle riktig; minimum 0p.

Hjelp

Risikoanalyse	Verdi-identifisering	Risikoidentifisering
Risikoevaluering	Risikorangering	Risikoberegning



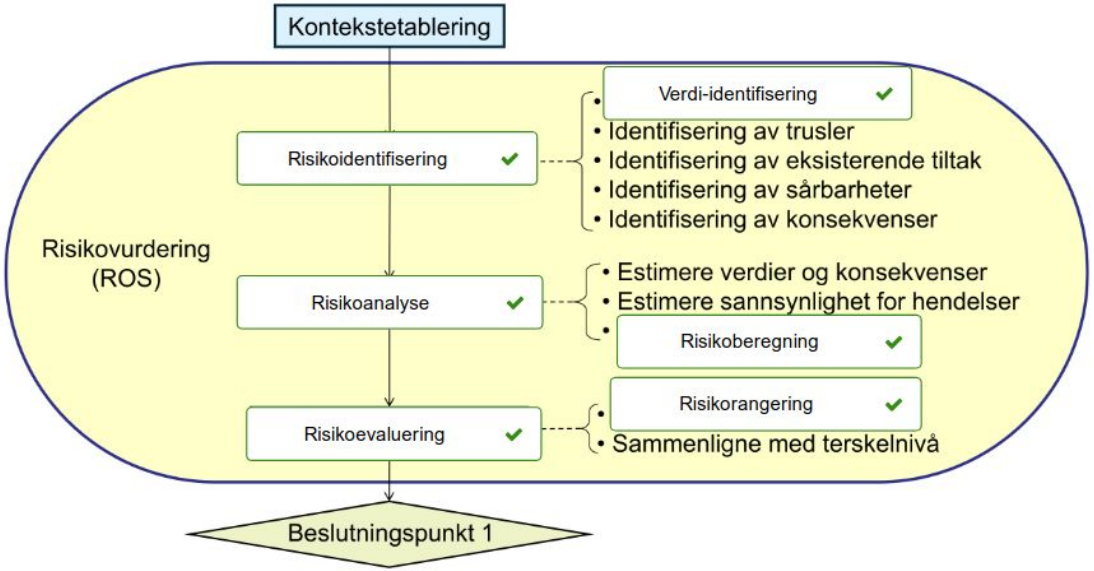
Maks poeng: 3

34 Prosess for risikovurdering

Figuren nedenfor viser prosess for risikovurdering der noen av trinnene mangler beskrivelse.
Sett inn elementene i riktig felt for å beskrive trinnene.
Poeng: 0,5p for hver riktig; -0.5p for hver feil; 0p for ubesvart; 3p for alle riktig; minimum 0p.

Hjelp

Risikoanalyse	Risikorangering	Verdi-identifisering
Risikoidentifisering	Risikoevaluering	Risikoberegning



Maks poeng: 3

Eksamen 2023

39 Risikohåndtering

Håndtering av risikoer er en del av risikostyring. For hvert utsagn nedenfor, indiker om det representerer en gyldig metode for å håndtere risiko.

Poeng: 0,5 for hver riktig; -0,5 for hver feil; 0 for ubesvart; maks 2, minimum 0.

Indiker om hvert utsagn er en gyldig metode for risikohåndtering.

	Nei	Ja
Aksepter risikoen, som dermed representerer restrisiko	○	○
Dele eller overføre risiko til andre, f.eks. med tjenesteutsetting eller cyberforsikring	○	○
Reduser risiko ved å implementere sikkerhetstiltak	○	○
Reduser risikonivået fra risikovurderingen ved å endre risikotabellen	○	○

Maks poeng: 2

39 Risikohåndtering

Håndtering av risikoer er en del av risikostyring. For hvert utsagn nedenfor, indiker om det representerer en gyldig metode for å håndtere risiko.

Poeng: 0,5 for hver riktig; -0,5 for hver feil; 0 for ubesvart; maks 2, minimum 0.

Indiker om hvert utsagn er en gyldig metode for risikohåndtering.

	Nei	Ja
Reduser risiko ved å implementere sikkerhetstiltak	○	○ ✔
Dele eller overføre risiko til andre, f.eks. med tjenesteutsetting eller cyberforsikring	○	○ ✔
Reduser risikonivået fra risikovurderingen ved å endre risikotabellen	○ ✔	○
Aksepter risikoen, som dermed representerer restrisiko	○	○ ✔

Maks poeng: 2

Eksamen 2024/2025

32 NSMs grunnprinsipper og NIST CSF

NSMs grunnprinsipper for IKT-sikkerhet, og NIST CSF (Cybersecurity Framework) er to standarder/veiledere for informasjonssikkerhet. Indiker om hvert utsagn nedenfor gjelder for NSM, NIST, begge eller ingen.

Poeng: 0,5 for hver riktig; -0,5 for hver feil; 0 for ubesvart; maks 2, minimum 0.

Indiker hva som gjelder for hvert utsagn.

	NSM	NIST	begge	ingen
Kategoriserer sikkerhetstiltak etter sikkerhetsfunksjoner/prosesser (f.eks. kartlegge, beskytte, oppdage, håndtere)	○	○	○	○
Standarden/veilederen må kjøpes	○	○	○	○
Er publisert på norsk	○	○	○	○
Kan brukes sammen med ISO/IEC 27001	○	○	○	○

Maks poeng: 2

32 NSMs grunnprinsipper og NIST CSF

NSMs grunnprinsipper for IKT-sikkerhet, og NIST CSF (Cybersecurity Framework) er to standarder/veiledere for informasjonssikkerhet. Indiker om hvert utsagn nedenfor gjelder for NSM, NIST, begge eller ingen.

Poeng: 0,5 for hver riktig; -0,5 for hver feil; 0 for ubesvart; maks 2, minimum 0.

Indiker hva som gjelder for hvert utsagn.

	NSM	NIST	begge	ingen
Kategoriserer sikkerhetstiltak etter sikkerhetsfunksjoner/prosesser (f.eks. kartlegge, beskytte, oppdage, håndtere)	○	○	✔	○
Standarden/veilederen må kjøpes	○	○	○	✔
Er publisert på norsk	✔	○	○	○
Kan brukes sammen med ISO/IEC 27001	○	○	✔	○

Maks poeng: 2